

Silicon Knights

**Alessandro Caterisano, Adriano Rossi, Alessandro Albiero, Damiano Di Biase,
Domenico Mendola, Joele Bernardi, Marco Pedrolo**

Server Linux

INCARICO

In questo laboratorio, useremo la riga di comando Linux per identificare i server in esecuzione su un dato computer.

- **Parte 1: Server**
- **Parte 2: Usare Telnet per Testare i Servizi TCP**

Accedo alla VM CyberOps Workstation, apro il terminale dei comandi ed inserisco il comando **sudo ps -elf** per osservare la lista dei processi in corso.

```
[analyst@secOps ~]$ sudo ps -elf
[sudo] password for analyst:
F S UID        PID     PPID    C  PRI   NI   ADDR  SZ  WCHAN  STIME TTY          TIME CMD
4 S root         1         0   0   80    0   -   5454  do_epo 08:20 ?        00:00:00 /sbin/init
1 S root         2         0   0   80    0   -           0 kthrea 08:20 ?        00:00:00 [kthreadd]
1 S root         3         2   0   80    0   -           0 kthrea 08:20 ?        00:00:00 [pool_workqueue_release]
1 I root         4         2   0   60  -20   -           0 rescue 08:20 ?        00:00:00 [kworker/R-rcu_gp]
1 I root         5         2   0   60  -20   -           0 rescue 08:20 ?        00:00:00 [kworker/R-sync_wq]
1 I root         6         2   0   60  -20   -           0 rescue 08:20 ?        00:00:00 [kworker/R-kvfree_rcu_reclaim]
1 I root         7         2   0   60  -20   -           0 rescue 08:20 ?        00:00:00 [kworker/R-slub_flushwq]
1 I root         8         2   0   60  -20   -           0 rescue 08:20 ?        00:00:00 [kworker/R-netns]
1 I root        10         2   0   80    0   -           0 worker 08:20 ?        00:00:00 [kworker/0:1-events]
1 I root        12         2   0   80    0   -           0 worker 08:20 ?        00:00:00 [kworker/u8:0-events_unbound]
1 I root        13         2   0   80    0   -           0 worker 08:20 ?        00:00:00 [kworker/u8:1-ipv6_addrconf]
1 I root        14         2   0   60  -20   -           0 rescue 08:20 ?        00:00:00 [kworker/R-mm_percpu_wq]
1 S root        15         2   0   80    0   -           0 smpboo 08:20 ?        00:00:00 [ksoftirqd/0]
1 I root        16         2   0   58   -   -           0 rcu_gp  08:20 ?        00:00:00 [rcu_preempt]
1 S root        17         2   0   58   -   -           0 rcu_bo  08:20 ?        00:00:00 [rcub/0]
1 S root        18         2   0   80    0   -           0 kthrea 08:20 ?        00:00:00 [rcu_exp_par_gp_kthread_worker/0]
1 S root        19         2   0   80    0   -           0 kthrea 08:20 ?        00:00:00 [rcu_exp_gp_kthread_worker]
1 S root        20         2   0  -40   -   -           0 smpboo 08:20 ?        00:00:00 [migration/0]
1 S root        21         2   0    9   -   -           0 smpboo 08:20 ?        00:00:00 [idle_inject/0]
1 S root        22         2   0   80    0   -           0 smpboo 08:20 ?        00:00:00 [cpuhp/0]
1 S root        23         2   0   80    0   -           0 smpboo 08:20 ?        00:00:00 [cpuhp/1]
```

Perché è stato necessario eseguire ps come root (premettendo il comando con sudo)?

Per osservare anche i processi avviati come root.

Avvio il servizio **nginx** con il comando **sudo /usr/sbin/nginx**. Inserisco il comando **ps -ejH** per vedere l'albero dei processi in esecuzione.

Come viene rappresentata la gerarchia dei processi da PS?

Viene utilizzato un sistema di indentazione, dove i sotto processi sono elencati di seguito con tabulazione e con lo stesso PID del processo padre.

Lancio il comando **netstat -tunap** per visualizzare i servizi web.

```
[analyst@secOps ~]$ sudo netstat -tunap
[sudo] password for analyst:
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:22             0.0.0.0:*               LISTEN      386/sshd: /usr/bin/
tcp        0      0 0.0.0.0:21             0.0.0.0:*               LISTEN      452/vsftpd
tcp        0      0 0.0.0.0:80             0.0.0.0:*               LISTEN      1216/nginx: master
tcp        0      0 0.0.0.0:6633           0.0.0.0:*               LISTEN      369/python3.9
tcp6       0      0 :::22                  :::*                   LISTEN      386/sshd: /usr/bin/
udp        0      0 10.0.2.15:68          0.0.0.0:*               *          294/systemd-network
```

Qual è il significato delle opzioni -t, -u, -n, -a e -p in netstat?

- **-t**: TCP, mostra servizi con protocollo **tcp**
- **-u**: UDP, mostra servizi con protocollo **udp**
- **-n**: NUMERIC, mostra indirizzi e porte in formato numerico.
- **-a**: ALL, mostra sockets in ascolto e non in ascolto
- **-p**: PROGRAM: Mostra PID e nome del servizio

L'ordine delle opzioni è importante per netstat?

```
[analyst@secOps ~]$ sudo netstat -patun
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      386/sshd: /usr/bin/
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      452/vsftpd
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      1216/nginx: master
tcp        0      0 0.0.0.0:6633            0.0.0.0:*               LISTEN      369/python3.9
tcp6       0      0 :::22                   :::*                    LISTEN      386/sshd: /usr/bin/
udp        0      0 10.0.2.15:68            0.0.0.0:*               LISTEN      294/systemd-network
[analyst@secOps ~]$
```

No, non importa in quale ordine si inseriscono le opzioni.

Esamino i dati dell'output di **netstat**.

Basandosi sull'output di netstat mostrato al punto (d), qual è il protocollo di Livello 4, lo stato della connessione e il PID del processo in esecuzione sulla porta 80?

- **Protocollo**: tcp
- **Stato**: Listen (In ascolto)
- **PID**: 1216

Sebbene i numeri di porta siano solo una convenzione, puoi indovinare che tipo di servizio è in esecuzione sulla porta 80 TCP?

Solitamente, per convenzione, la porta 80 corrisponde al servizio **HTTP**.

```
tcp        0      0 0.0.0.0:www-http         0.0.0.0:*               LISTEN      1216/nginx: master
```

Combino l'utilizzo di **ps** con i risultati **netstat**, lanciando il comando **sudo ps -elf | grep 1216** (mio PID di nginx).

```
[analyst@secOps ~]$ sudo ps -elf | grep 1216
[sudo] password for analyst:
1 S root      1216      1 0 80   0 - 3723 sigsus 10:55 ?        00:00:00 nginx: master process /usr/sbin/nginx
5 S http      1217    1216 0 80   0 - 3827 do_epo 10:55 ?        00:00:00 nginx: worker process
0 S analyst   1485    1028 0 80   0 - 1615 anon_p 12:08 pts/1    00:00:00 grep 1216
[analyst@secOps ~]$
```

Il processo PID 395 è nginx. Come si potrebbe concludere questo dall'output sopra?

Oltre che averlo confermato con netstat, lo deduciamo dal fatto che nell'ultima colonna è indicato come “**master process**” oltre al path che conduce proprio ad nginx.

Cos'è nginx? Qual è la sua funzione? Usa google per saperne di più su nginx.

Nginx è un software open source leggero e ad altissime prestazioni utilizzato principalmente come web server, reverse proxy, bilanciatore di carico e cache HTTP. È celebre per la sua capacità di gestire milioni di connessioni simultanee consumando pochissime risorse di sistema.

La seconda riga mostra che il processo 396 è di proprietà di un utente chiamato http e ha il processo numero 395 come processo genitore. Cosa significa? È un comportamento comune?

Sì, è un comportamento del tutto normale quando si tratta di server web come nginx. Il processo padre (**395**) per l'avvio del server, che in questo caso, di base, sarà in ascolto sulla porta 80, può essere eseguito solo da utenti con privilegi di root, mentre delega la sua gestione ad un utente con privilegi minimi (**http**) per ragioni di sicurezza. Se un attaccante dovesse iniettare codice malevolo remoto, lo farebbe verso un utente con privilegi minimi (principio del **least privilege**).

Perché l'ultima riga mostra `grep 395`?

Dal momento che abbiamo utilizzato la pipe per combinare **ps** e **grep** per cercare i processi attivi che includessero il PID indicato, abbiamo avviato nello stesso istante il processo del **grep** stesso, che includendo il numero PID nella ricerca, è comparso nella nostra lista.

Avvio il client **telnet** e mi collego al localhost sulla porta 80, comunicando con il server **nginx** attivo.

```
[analyst@secOps ~]$ telnet 127.0.0.1 80
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.
ciao
HTTP/1.1 400 Bad Request
Server: nginx/1.28.0
Date: Mon, 18 May 2026 17:14:56 GMT
Content-Type: text/html
Content-Length: 157
Connection: close

<html>
<head><title>400 Bad Request</title></head>
<body>
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx/1.28.0</center>
</body>
</html>
Connection closed by foreign host.
[analyst@secOps ~]$
```

Perché l'errore è stato inviato come pagina web?

Proprio perchè **nginx** è un servizio web che opera sulla porta 80, ci fornirà risposte in **html**.

Infine tento connessione verso la porta 68 utilizzando client **telnet**.

Usa Telnet per connetterti alla porta 68. Cosa succede? Spiega.

```
[analyst@secOps ~]$ telnet 10.0.2.15 68
Trying 10.0.2.15...
telnet: Unable to connect to remote host: Connection refused
```

Poichè il protocollo del DHCP client comunica in UDP, ricevo un messaggio di connessione rifiutata. Telnet comunica solo in TCP e funziona con connessione three-way-handshake.

Domande di Riflessione

Quali sono i vantaggi dell'uso di netstat?

Netstat è molto importante per visualizzare tutte le connessioni attive nel dato momento, ed avere informazioni a riguardo come nome, protocollo o PID. Utile anche per trovare connessioni stabilite da malware per il C2. Può inoltre filtrare o fornire output più precisi aggiungendo delle opzioni nel prompt.

Quali sono i vantaggi dell'uso di telnet? È sicuro?

Telnet non è sicuro, poiché trasmette tutti i dati in chiaro, ma può comunque essere utile grazie alla sua velocità, possibilità di cambiare porta o per eseguire dei test rapidi verso i servizi attivi. Inoltre, spesso, il server in ascolto risponde con informazioni utili, come il nome del server e la versione.